

**SAFE STUDENT**

**RELATÓRIO DE AUDITORIA TÉCNICA E DE CONFORMIDADE —**  
**V2.0**

Revisão sênior de requisitos, UML/DER, código, privacidade, testes e evidências

## 1 OBJETIVO

A auditoria V2.0 confronta cada afirmação técnica com o comportamento observável do MVP. A revisão evita tratar metas futuras como funcionalidades implementadas e evita tratar resultados históricos de pesquisa como evidência auditada quando os registros primários não estão disponíveis.

## 2 ACHADOS E CORREÇÕES

| Severidade | Achado                                                                                     | Correção V2                                                                           |
|------------|--------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| Crítico    | Casos de uso com cruzamentos e linhas que pareciam setas de fluxo.                         | Diagramas separados por ator; associação sólida simples, sem seta.                    |
| Crítico    | Classes misturavam conceito, perfil e estrutura relacional.                                | Modelo conceitual separado do DER; Usuario único com PerfilUsuario e multiplicidades. |
| Crítico    | DER parecia fluxograma.                                                                    | DER lógico com PK/FK/UQ e cardinalidades, sem setas de processo.                      |
| Alto       | Referência OWASP MASVS em aplicação web.                                                   | OWASP ASVS 5.0.0 usado como referência de segurança web.                              |
| Alto       | Gestão podia visualizar mensagens/notificações privadas de terceiros.                      | Escopo restrito aos participantes/destinatários; testes de regressão.                 |
| Alto       | Diretório devolvia dados pessoais além do necessário.                                      | Projeção mínima: id, nome, perfil e status.                                           |
| Alto       | CSV de validação incluía DEMO_SEED.                                                        | Exportação somente de APRESENTACAO.                                                   |
| Médio      | Taxa de presença usava corte UTC diferente do dia escolar.                                 | Cálculo unificado pela função dateKey do fuso escolar.                                |
| Médio      | Token de novo aluno não verificava colisão explicitamente.                                 | Geração com verificação de unicidade.                                                 |
| Médio      | Base mutável db.json era versionada.                                                       | db.runtime.json é criado da seed e ignorado pelo Git.                                 |
| Acadêmico  | Números históricos de pesquisa apareciam como resultado sem evidência primária localizada. | Status da pesquisa permanece Parcial; nova coleta real é necessária.                  |

## 3 REQUISITOS E MODELAGEM

Os requisitos funcionais foram reescritos como obrigações observáveis com critério de aceite. Os requisitos não funcionais indicam como devem ser comprovados. A modelagem usa associação sem seta em casos de uso e classes; o DER apresenta relacionamentos com chaves e cardinalidades; o diagrama de sequência usa setas porque elas representam mensagens; o diagrama de componentes mostra somente a arquitetura efetivamente implementada.

## 4 AUDITORIA DO CÓDIGO

| Área          | Conclusão                                                                                                          |
|---------------|--------------------------------------------------------------------------------------------------------------------|
| server.js     | Autenticação, autorização, minimização, presença, mensagens, notificações, relatórios, feedback e reset revisados. |
| lib/domain.js | RBAC, escopo de alunos, sequência de presença e taxa por                                                           |

|                 |                                                                                                               |
|-----------------|---------------------------------------------------------------------------------------------------------------|
|                 | dia escolar revisados.                                                                                        |
| lib/security.js | script + timingSafeEqual adequados ao MVP; não são apresentados como arquitetura de alta carga.               |
| public/         | Interface usa API autenticada e escape de conteúdo; controles visuais não substituem autorização server-side. |
| data/           | Seed sintética versionada; runtime mutável não deve ser commitado.                                            |
| tests/          | Domínio, segurança, API e regressões de privacidade.                                                          |

## 5 TESTES

Na revisão sênior, a suíte V2 foi executada localmente em Node.js 22 com 24 testes aprovados e 0 falhas. O workflow de CI permanece configurado para Node.js 18, 20 e 22 e deve ser conferido separadamente antes da entrega final; o resultado local não deve ser descrito como se fosse um status do GitHub Actions.

## 6 EVIDÊNCIA EXTENSIONISTA

A pesquisa de campo continua Parcial até existir evidência primária real: formulários/termos preenchidos, respostas anonimizadas ou CSV de coleta que permita reproduzir os resultados. Não se deve inventar participantes, respostas, percentuais ou médias. Registros DEMO\_SEED são ilustrativos e não constituem pesquisa.

## 7 SITUAÇÃO V2

| Dimensão          | Status                                                      |
|-------------------|-------------------------------------------------------------|
| Código/MVP        | Revisado; suíte local 24/24.                                |
| Requisitos        | Reescritos e rastreáveis.                                   |
| UML/DER           | Refazidos com notação formal e responsabilidades separadas. |
| Documentação      | Sincronizada com a revisão V2 nos artefatos finais.         |
| Pesquisa de campo | Parcial até evidência primária real.                        |
| Produção          | Fora do escopo: MVP acadêmico local, não homologado.        |

## REFERÊNCIAS

OBJECT MANAGEMENT GROUP. Unified Modeling Language (UML), Version 2.5.1.

OWASP FOUNDATION. Application Security Verification Standard (ASVS) 5.0.0.

WORLD WIDE WEB CONSORTIUM. Web Content Accessibility Guidelines (WCAG) 2.2.

BRASIL. Lei nº 13.709/2018 — Lei Geral de Proteção de Dados Pessoais.